Skema Keamanan Sistem HRIS — Kebijakan & Arsitektur Keamanan v1.0

Versi: 1.0
Tanggal: 2025-08-23
Penulis: Tim Security / DevOps (disiapkan untuk: Atar)

Dokumen ini mendeskripsikan skema keamanan menyeluruh untuk HRIS All-in-One (dev & prod). Menjelaskan kebijakan, arsitektur, kontrol teknis dan organisatoris, proses operasi keamanan, runbook insiden, dan kriteria penerimaan. Tujuan: melindungi kerahasiaan, integritas, dan ketersediaan data karyawan dan finansial (payroll).

---

1. Ringkasan & Prinsip Keamanan

- **Target**: Data sensitif (NIK, NPWP, rekening bank, payslip, payroll computations) harus terlindungi end-to-end.
- **Prinsip desain**: defense-in-depth, least privilege, zero trust, secure by default, auditable, dan automatable.
- **Scope**: seluruh stack—frontend (Next.js 14), backend (NestJS 10), DB (Postgres 16), cache (Redis 7), event bus (Kafka 3.7), identity (Keycloak 24), infra (Docker/K8s), storage (S3/MinIO), dan pipeline CI/CD (GitHub Actions).

---

2. Threat Model Singkat

2.1 Aset kritikal

- Master data karyawan (identitas, NIK, NPWP).
- Payroll calculations & payslips.
- Bank transfer files.
- Audit logs & event stream.
- Secrets (DB credentials, signing keys).

2.2 Aktor ancaman

- External attacker (credential stuffing, phishing).
- Malicious insider (privileged user mis-use).
- Supply chain compromise (dependency attack).
- Compromised CI pipeline.
- Misconfigured infra (exposed S3, open DB port).

2.3 Vektor serangan utama

- API abuse (IDOR, broken auth).
- SQL/NoSQL injection / deserialization.
- Cross-site scripting (XSS) & CSRF.
- Compromised third-party libs or container images.
- Lateral movement after host compromise.

---

3. Governance & Peran

- **Data Owner**: CHRO / Finance — bertanggung jawab klasifikasi data & retensi.
- **Security Owner**: Security Lead — kebijakan, audit, pentest, IR.
- **Infra Owner**: DevOps — konfigurasi infra & ops.
- **App Owner**: Tim Product/Engineering — implementasi kontrol app.
- **Compliance**: Legal — memetakan regulasi (UU PDP Indonesia, PDPA/GDPR bila perlu).

Meeting rutin: security monthly review + release gate meeting untuk modul finansial (payroll).

---

4. Identitas & Akses (AuthN/AuthZ)

4.1 Identity Provider (IdP)

- Gunakan **Keycloak v24** (dev/prod). Realm `hris-prod` / `hris-dev`.
- Konfigurasi: OIDC + SAML, client per aplikasi (`web`, `api`, `admin`), PKCE untuk public clients, confidential for backend.
- Enable **MFA (TOTP & WebAuthn)** untuk semua admin & finance roles.

4.2 Authentication Policies

- Password policy: min 12 chars, complexity, reject common passwords, temp lockout after 5 failed attempts, password history 5.
- Token lifetimes: access token short (10–15m), refresh token rotate & one-time use, refresh token TTL 30d, revoked on logout.
- Session revocation on role change/termination.

4.3 Authorization Model

- Implement **RBAC** awal + **Policy-based (ABAC)** via OPA/oso untuk rules kompleks (contoh: approval rules, payroll thresholds).
- Administrative & finance actions require elevated role + MFA.
- Row-level access: PostgreSQL **RLS** enforced per `tenant_id` & `entity_id` for multi-tenancy.

4.4 Service-to-Service Auth

- Mutual TLS between critical services (optional) or mTLS at gateway.
- Services identify via short-lived mTLS certs (SPIRE) or signed JWTs (Kubernetes service account tokens with limited scope).
- For external integrations (banks, e-sign), use dedicated service accounts + IP allow-list + HMAC signing for webhooks.

---

5. Network & Perimeter Controls

5.1 Network segmentation

- Separate networks: management, app, data plane.
- K8s namespaces per environment; network policies restricting pod-to-pod communication — deny by default.

5.2 Ingress & API Gateway

- All external traffic hits API Gateway (e.g., Kong/NGINX/Envoy) with WAF (ModSecurity rules + vendor ruleset).
- Terminate TLS at edge (TLS 1.3 preferred; fallback TLS 1.2 with strong ciphers).
- Enforce rate limiting, IP reputation filtering, and geo restrictions if needed.

5.3 Internal comms

- Encrypt internal traffic using TLS; prefer mTLS for sensitive channels (DB proxy, kafka).
- Redis & Postgres not exposed publicly; accessible only from app subnet/security group.

---

6. Data Protection & Encryption

6.1 Transport

- TLS 1.3 (recommended) or TLS 1.2+ with strong ciphers for all external & internal endpoints.
- HSTS & secure headers on web responses.

6.2 At-rest

- Object storage (S3/MinIO): server-side encryption (SSE) with KMS keys.
- Database: disk encryption and column/field encryption for PII (NIK, NPWP, nomor rekening) using application-level encryption or DB-level TDE if available.
- Redis: enable AUTH and, where supported, TLS. Do not store raw secrets in Redis; use tokens with short TTL.

6.3 Key Management

- Use **KMS** (Cloud KMS or HashiCorp Vault + HSM) for KMS key storage.
- Key rotation policy: rotate data-encryption keys yearly; rotate envelope keys quarterly; rotate credentials 30–90 days for CI/service accounts.
- Access to KMS governed by IAM roles & least privilege.

6.4 Field-Level Encryption

- Sensitive fields encrypted in application layer before DB insert (e.g., libs like AWS Encryption SDK or libsodium).
- Store ciphertext + KMS key metadata; restrict read access to app services with proper privileges.

---

7. Secrets Management

- Use **HashiCorp Vault** (recommended) or cloud secrets manager; do **NOT** store secrets in repo or env files unencrypted.
- Use dynamic secrets (DB credentials short-lived) when possible.
- CI/CD: use GitHub Actions encrypted secrets + HashiCorp Vault agent on runners for ephemeral credentials.
- Scan repos for accidental secret leaks (git-secrets) on pre-commit & in CI.

---

8. Application Security

8.1 Secure SDLC

- SAST (e.g., Semgrep/CodeQL) on PR.
- Dependency scanning (Snyk/Dependabot) automated.
- Container image scanning (Trivy) during build.
- DAST (OWASP ZAP) during staging.
- Security review for high-risk changes (payroll logic, cryptography, integrator adapters).

8.2 Input Validation & Output Encoding

- Validate all inputs server-side (class-validator/Zod) and sanitize outputs.
- Use parameterized queries via Prisma to prevent SQL injection.
- Escape & Content Security Policy (CSP) to reduce XSS risk.

8.3 Session & Cookie Security

- Cookies: `Secure`, `HttpOnly`, `SameSite=Strict` for session cookies.

- Token storage: prefer in-memory or secure httpOnly cookie for web; avoid localStorage for sensitive tokens.

8.4 CSRF Protection

- Use double submit cookie or framework middleware. Protect state-changing endpoints.

8.5 Rate Limiting & Abuse Controls

- Global + per-user rate limits at API gateway; per-endpoint thresholds for sensitive endpoints (login, payroll simulate).
- Bot detection (device fingerprinting, heuristics) and CAPTCHA for suspicious flows.

---

9. Infrastructure & Container Security

9.1 Image Build & Registry

- Use minimal base images (distroless/alpine slim).
- Reproducible builds; sign images (cosign).
- Private registry with role-based access; retention & immutable tags for prod images.

9.2 Kubernetes Hardening

- RBAC for K8s; use least privilege for service accounts.
- Pod Security Admission: restrict privileged containers, hostNetwork, hostPath.
- Limit container capabilities; run as non-root user.
- Resource quotas & limits; liveness/readiness probes.

9.3 IaC Security

- Scan Terraform with `tflint` & `tfsec`.
- Secrets never in state files; use remote state with encryption & ACL.
- Code review required for infra changes.

---

10. Logging, Monitoring & SIEM

10.1 Log collection

- Centralized logging (Loki/ELK) with structured JSON logs including `correlation_id`, `user_id`, `tenant_id`.
- Log levels: DEBUG (dev only), INFO, WARN, ERROR.
- Mask PII in logs (mask NIK, NPWP, full account numbers) — never log full sensitive identifiers.

10.2 Retention & Integrity

- Retention: audit logs & payroll artifacts minimum 7 tahun (configurable).
- Immutable storage (WORM) for critical audit logs/payslip artifacts.
- Sign or checksum critical artifacts (payroll runs) and store checksum metadata.

10.3 Monitoring & Alerts

- Metrics in Prometheus; dashboards in Grafana.
- Alerts: high error rate, auth failure surge, migration job failures, unusual export/download volumes.
- Integrate with PagerDuty/Opsgenie for on-call.

10.4 SIEM & Forensics

- Forward critical logs to SIEM (Splunk/ELK/Cloud SIEM) for correlation & threat hunting.
- Keep forensic-quality logs (timestamps, immutable) for incident investigation.

---

11. Event Bus & Data Integrity (Kafka)

- Use TLS + client auth for Kafka connections.
- ACL enforcement on topics (producer/consumer).
- Schema registry (Avro/JSON Schema) with compatibility checks; topic retention policies.
- Consumer offsets monitored; replay capability for downstream recovery.

---

12. Database Security (Postgres 16)

- Enforce network restrictions (private subnet, no public exposure).
- Use RLS policies for tenant enforcement.
- Principle of least privilege for DB users (read-only for analytics).
- Backup encryption & access control; PITR enabled.

---

13. Backup, DR & Business Continuity

- Daily encrypted backups + WAL shipping for PITR (RPO $\leq$ 15 menit).
- DR region replication & documented RTO $\leq$ 1 jam.
- Quarterly restore drills with documented results.

---

14. Third-Party Integrations & Supply Chain

- Inventory all third-party vendors (bank, e-sign, attendance device, cloud).
- Contractual security requirements: SOC2/ISO27001 evidence where possible.
- External integrations use dedicated service accounts & IP allowlist; only required scopes.
- Dependency policy: only approved registries; pinned versions; supply chain scanning.

---

15. Privacy, Data Minimization & Retention

- Klasifikasi data: PII, Sensitive PII, Financial.
- Retention policy: default 7 tahun untuk payroll & audit; configurable per tenant.
- Data subject rights process (view/export/delete) & process to handle PDP requests.

---

16. Penetration Testing & Validation

- Annual 3rd-party pentest (external & internal).
- Quarterly internal red-team focused on high-risk areas (payroll & file exports).
- Remediation SLA: critical findings $\leq$ 7 hari, high $\leq$ 30 hari.

---

17. Secure Release & Change Management

- Security review checklist required for PRs touching payroll/identity/crypto.
- Feature flags for risky changes; canary rollout with monitor & automatic rollback.
- Pre-deployment backup & dry-run for payroll changes.

---

18. Incident Response (IR)

18.1 Triage flow

1. Detection → create incident in tracker (Jira/ServiceNow) with severity.
2. Triage by on-call security + infra.
3. Containment (isolate service / revoke keys / block IPs).
4. Eradication & recovery (patch, redeploy, restore backups).
5. Post-mortem & lessons learned.

18.2 Communication

- Notification templates for internal stakeholders & regulators.
- For data breach involving personal data: legal & compliance to coordinate external disclosure per law (UU PDP) and timelines.

18.3 IR Playbook (contoh untuk data leak)

- Segera revoke compromised credentials (service & user).
- Rotate KMS keys if key compromise suspected.
- Snapshot forensic logs; escalate to external forensics if needed.
- Notify affected tenants + regulator in required timeframe.

---

19. Acceptance Criteria & Security KPIs

- No critical OWASP vulnerabilities in prod.
- SAST/DAST pass gating on main merges.
- 0 secrets in repo (scan).
- MFA enabled for all admin & finance users.
- Incident detection mean time to detect (MTTD) < 15 min; mean time to remediate (MTTR) < 4 jam untuk critical.

---

20. Checklist Security Pre-Release (wajib untuk payroll changes)

- [ ] Code review by security owner.
- [ ] SAST & dependency scan green.
- [ ] DAST on staging successful (no critical).
- [ ] Dry-run payroll simulation & reconciliation signed by finance.
- [ ] Backup & snapshot complete.
- [ ] Feature flags available for rollback.

---

21. Runbook Templates & Artefak

- Incident report template (timestamp, impact, root cause, remediation).
- Security change request form.
- Emergency contact list (security, infra, legal, finance).

---

22. Implementasi Teknis & Config Sample (ringkas)

- TLS: terminate with Let's Encrypt / ACM; cipher suites modern; HTTP/2 & HSTS.
- Cookie: `Set-Cookie: session=...; Secure; HttpOnly; SameSite=Strict; Path=/; Max-Age=3600`.
- CSP minimal: `Content-Security-Policy: default-src 'self'; script-src 'self' 'nonce-...'; object-src 'none'`.
- CORS: whitelist specific domains; do not use `*` for credentials endpoints.
- Rate limit: 100 req/min per IP normal; 10 req/min for login endpoints with adaptive backoff.

---

23. Roadmap Implementation Prioritas

1. Secrets management (Vault) + CI integration.
2. Keycloak w/ MFA & RBAC mapping.
3. RLS + Prisma middleware for tenant enforcement.
4. Centralized logging & SIEM ingestion.
5. SAST/DAST in CI, container signing & image scanning.
6. Annual pentest + quarterly red team.

---

24. Dokumentasi & Pelatihan

- Dokumentasi kebijakan security tersedia untuk dev & ops.
- Pelatihan keamanan tahunan untuk dev dan onboarding security untuk new hires.
- Drill IR setahun 2x.

---

25. Penutup

Dokumen ini harus diperlakukan sebagai living document — review minimal tiap 6 bulan, atau setelah perubahan signifikan (mis. pergantian provider, penemuan kelemahan, upgrade besar). Untuk implementasi, tim DevOps & Security akan buat backlog tiket terprioritaskan untuk sprint-by-sprint execution.

Lampiran: Template Incident Report & Emergency Contact akan disediakan terpisah bila kamu mau.

Kalau mau, gue bisa langsung generate: - playbook incident template (markdown), atau - contoh policy OPA/rego untuk approval rules, atau - contoh config Keycloak realm JSON untuk dev/prod.

Pilih salah satu dan gue gas bikin filenya.